

[Engineering / Security / Third Parties](#) / Vendor and Sub-Processor Security Review

security

vendor

sub-processor

compliance

review

Vendor and Sub-Processor Security Review

Space	Engineering / Security / Third Parties
Page ID	48431590
Labels	security, vendor, sub-processor, compliance, review
Page owner	Priya Shah, Security Lead
Last updated	2026-05-11 by Priya Shah
Exported	Exported from Confluence on 2026-08-12
Classification	Internal - do not forward

Contents

1. Scope
2. Definitions
3. Intake
4. Risk tiers
5. Review steps
6. Approval
7. Ongoing
8. Offboarding
9. Register

1. Scope

Every third party that receives, stores, or can access Beacon customer data or contact data, and every tool that runs in Beacon's production path, goes through this review before any data is shared or any integration goes live. This is the process behind the Vendor Security Review Policy in Studio (policy.vendor-security). The policy says what is required. This page says how.

"Customer data" here includes workspace configuration, member identities, and billing records. "Contact data" is the audience: addresses, numbers, device tokens, attributes, events. Contact data is the higher-risk category because it belongs to our customers' customers.

2. Definitions

Vendor. Any third party Beacon pays or contracts with for a service.

Sub-processor. A vendor that processes customer or contact data on Beacon's behalf. Sub-processors are listed in the trust center and customers are notified of changes. Every sub-processor is a vendor; not every vendor is a sub-processor.

Production path. Anything that, if it failed or were compromised, would affect message delivery, the API, the web app, billing, or data integrity.

3. Intake

The requesting team opens a Vendor Review ticket in the security tracker with:

- Vendor name, website, and the service Beacon will use.
- What data will flow to them, in which direction, and why.
- Whether they will hold contact data (makes them a sub-processor).
- Whether they are in the production path.
- The internal owner who will be accountable for the relationship.
- Target go-live date.

Tickets without a named internal owner are returned. Somebody has to be the person who gets paged when the vendor has an incident.

Start the review at least four weeks before you need the vendor live. Two weeks for Tier 3. Reviews requested the week of a launch get the answer "no, not yet," and that is not Security being difficult.

4. Risk tiers

Tier	Criteria	Review depth	Re-review
Tier 1	Sub-processor holding contact data, or in the production path with write access	Full questionnaire, current independent audit report, architecture review, contract review, penetration test summary	Annual
Tier 2	Holds customer data but not contact data, or production-path read-only	Questionnaire, audit report or equivalent, contract review	Every two years
Tier 3	No customer or contact data; not in production path	Short questionnaire, terms review	On material change

Examples: an email delivery partner is Tier 1. A support ticketing tool that sees customer names and emails but no audience data is Tier 2. A design tool is Tier 3.

When in doubt, the tier is the higher one.

5. Review steps

5.1 Questionnaire

Send the Beacon vendor questionnaire (template in this space). Tier 1 and 2 receive the full version; Tier 3 receives the short one. Give the vendor two weeks. A vendor that cannot answer a security questionnaire in two weeks is telling you something.

5.2 Evidence

Tier 1 and 2 must provide a current independent audit report or an equivalent that Security accepts. "Current" means covering a period ending within the last 12 months. A bridge letter covers a gap of up to three months. Marketing pages about security do not count as evidence.

Tier 1 additionally provides a penetration test summary from the last 12 months and an architecture description sufficient to understand where Beacon's data sits, how it is encrypted, who at the vendor can access it, and how it is deleted.

5.3 Contract

Legal reviews the agreement. Tier 1 and 2 require data processing terms covering: processing only on Beacon's instructions, confidentiality, security measures, sub-processor flow-down with notification, breach notification within a defined period (Beacon's standard ask is 48 hours), assistance with data requests, deletion or return on termination, and audit rights. Do not sign a vendor's click-through for a Tier 1 or Tier 2 service.

Follow local law for what is required in the agreement; Legal determines the specifics per vendor. Security clears the security terms, Legal clears the rest.

5.4 Technical integration review

For production-path vendors: how are credentials stored and rotated, what is the blast radius if the vendor is compromised, can Beacon cut them off in under an hour, and what is the fallback. Document the kill switch on the vendor's register entry. If there is no kill switch, one is built before go-live.

5.5 Findings

Security records findings as Blocker, Required, or Advisory.

- **Blocker.** Go-live does not proceed until resolved. Example: contact data stored unencrypted at rest; no breach notification term.
- **Required.** Go-live may proceed with a dated remediation plan the vendor has agreed to in writing. Reviewed at the 90-day check.
- **Advisory.** Noted. No action required.

6. Approval

Security & Compliance signs off. For Tier 1, the Security lead signs personally. For Tier 2 and 3, a Security engineer may sign with the lead's review. The internal owner and Legal countersign the register entry.

Sub-processors are added to the trust center list on approval, with the customer notification going out per the trust center's notice period, before any contact data flows. Do not skip the notice period to hit a launch date.

Approval is recorded on the register with: tier, date, findings, remediation dates, kill switch, internal owner, re-review date.

7. Ongoing

- **Re-review** per tier schedule. The register generates the reminder to the internal owner 60 days ahead. A vendor whose re-review is more than 30 days overdue is flagged on the register and raised at the monthly security review.
- **Incidents.** Any incident involving a vendor is linked to their register entry from the incident write-up (Incident Response, section 8). A Tier 1 vendor incident that touched contact data triggers an immediate re-review regardless of schedule.
- **Change.** The internal owner notifies Security when the data flow changes, the vendor is acquired, the vendor changes their own sub-processors, or the service moves regions. Any of these can move the tier.
- **Access review.** Quarterly, the internal owner confirms which Beacon staff hold credentials to the vendor and removes anyone who has moved teams or left.

8. Offboarding

When Beacon stops using a vendor:

1. Internal owner opens an offboarding ticket.
2. Revoke Beacon credentials at the vendor and the vendor's credentials in Beacon.
3. Request deletion or return of all Beacon data per the contract. Get written confirmation with a date.
4. Remove from the trust center list (sub-processors) with the customer notification.
5. Close the register entry with the deletion confirmation attached.

Data does not stop being our responsibility because we stopped paying the invoice.

9. Register

The live register is the `Vendor Register` database in this space. Columns: vendor, service, tier, sub-processor (yes/no), internal owner, approval date, re-review date, open findings, kill switch, status. Export it monthly to the security review pack.

Current counts as of the last export: 6 Tier 1, 14 Tier 2, 31 Tier 3. Two Tier 2 re-reviews are overdue and are being chased by the internal owners.

Done when (for a new vendor): ticket complete with owner; tier assigned; questionnaire and evidence received; contract cleared by Legal and Security; kill switch documented for production path; findings recorded with dates; Security sign-off; register entry created; trust center updated with notice served, if sub-processor.